

XYZ-guard — Open-Source Launch Brief

One-page executive brief · Internal working document

The Opportunity in One Sentence

Open-source XYZ-guard as **the action-safety layer for AI agents** — the only gateway that scores every tool call 0–100 and routes medium-risk actions to a human — targeting security/governance teams protecting high-blast-radius agents, a niche no competitor owns.

Market Context (why now)

- **Two markets, both growing ~30%+:** AI gateways (~\$3.5B, 29.4% CAGR) and LLM guardrails (~\$2B, 32.5% CAGR). Guardrails grow faster and attract the M&A money.
 - **The market is consolidating in security:** Palo Alto acquired Portkey; Check Point acquired Lakera (~\$300M); agentgateway went to the Linux Foundation. Budget is flowing to security buyers, not gateway shoppers.
 - **Regulatory tailwind:** EU AI Act high-risk enforcement (Aug 2026) pushes regulated industries toward exactly this kind of runtime action oversight.
-

The Niche to Own

The "agent action firewall" — per-call risk scoring + a human-in-the-loop *intervene* tier + behavioral safety, dropped in with zero agent code.

Three defensible pillars (nothing competitors fully match): 1. **Graded enforcement** — allow / *human-review* / block, not binary allow/deny. 2. **Behavioral safety** — loop / drift / hallucination / contradiction detection + circuit breaker + checkpoint-rollback. 3. **Zero-code, any-language** deployment across three modes (incl. transparent NAT).

Everything else — MCP, routing, cost, control plane — is **table stakes reached**, used to prove completeness, never to lead.

Target Market

Primary buyer

Platform-security / AI-governance owner
(not the individual agent dev)

Beachhead	The "build-your-own" segment — enterprises already building custom safety because nothing off-the-shelf does action-safety their way
Wedge use cases	High-blast-radius agents: DevOps/infra, financial ops, customer-data actions; regulated industries (finance, pharma)
Category framing	Lean "agent action <i>guardrail</i> ," not "AI gateway" — higher-value, less-crowded

Competitive Snapshot

Competitor	Strength	Not their lane
LiteLLM	OSS mindshare leader (~52.6K stars)	No risk scoring / intervene tier
Portkey (Palo Alto)	24,000+ orgs; managed enterprise	Binary tool decisions
Bifrost	Performance, provider breadth	Suggestion, not enforcement
agentgateway	MCP+A2A, Linux Foundation	Binary authz, no scored tier
Lakera / NeuralTrust	Content/prompt security	Screen what agents <i>say</i> , not <i>do</i>

XYZ-guard today: ~0% measured share — a Beta entrant with an unclaimed niche.

Pre-Launch Readiness Checklist

- [] **Resolve name collision** with "Lasso Security" — always pair with "per-call action safety"; never use bare "risk score."
- [] **Publish benchmarks** (even modest latency/throughput) — competitors publish theirs.
- [] **Ship JWT/identity auth** (currently planned, not shipped) — table stakes for the security buyer.

- [] **Write a security-posture doc** — lean into in-process, deterministic, no-phone-home (contrast the LiteLLM PyPI compromise).
- [] **Confirm internal positioning** vs. Bedrock Guardrails / AgentCore as complementary (content vs. action), not competitive.
- [] **Decide monetization motion** — enterprise tier (SSO, audit, support) ready at launch; stars ≠ revenue.
- [] **Governance/license** — Apache-2.0 confirmed; decide contribution model and possible foundation path.
- [] **Positioning + messaging one-pager** — done (see companion doc).

The Bottom Line

Don't sell the feature list — **own the action-safety niche**. Lead with the risk-scored intervene tier + behavioral safety, aimed at security/governance buyers protecting high-blast-radius agents, with the build-your-own crowd as the beachhead. Close the credibility gaps (benchmarks, auth, security posture, name collision) before the repo goes public.